

Penetration Testing Report

WEEK 4 CAPSTONE PROJECT

Authorized internship practice assessment

PROJECT DETAILS	
Prepared by	Asher Maxwell
Cyber Security Mentor	Waqas Karim, CCIE
Organization	Network Walks
Batch / Project	B082 Week 4 Capstone Project
Target	https://medirozahospital.com
Report date	15 September 2026
Version	1.0 README-based assessment report

Confidential | Educational project evidence

This report documents an authorized practice test, as confirmed by the project owner. It consolidates the repository README and its embedded screenshots. No new testing of the target was performed in preparing this report.

Evidence dates include a 9 September 2026 HTTP response and 15 September 2026 local file timestamps. The full engagement window is not specified.

Executive summary

The capstone project documents a chain of weaknesses affecting the practice patient portal: distinguishable login errors exposed a valid username; SQL-related input tests produced database errors; the reported authentication bypass was followed by access to three protected reports. Offline dictionary testing recovered all three PDF passwords. Metadata in an unlocked report then pointed to a forgotten backup directory containing a SQL file. [R1]

The principal risk is loss of confidentiality. The evidence shows readable laboratory reports and a browsable database-backup listing. The README also reports access to an employee record in the SQL file. If equivalent controls protected real data, the same sequence could expose medical and personnel information. The evidence does not establish database modification, remote code execution, or compromise of the entire server.

ID	Finding	Severity	Evidence basis
F01	Username enumeration	Medium	Two distinct login responses
F02	SQL injection / reported login bypass	High*	SQL errors + subsequent portal view
F03	Confidential PDF access after bypass	High*	Download links + readable reports
F04	Weak PDF passwords	High	Three recovery results
F05	Sensitive PDF metadata	Medium	ExifTool output
F06	Exposed /old/ SQL backup	High	Directory listing + README account

*The bypass chain is reported by the project owner and supported by the screenshot sequence, but its successful request is absent. Ratings are qualitative analyst judgments for this practice scenario; they are not CVSS scores. F03 describes downstream impact and is not proof of a separate cross-user authorization flaw.

Priority action

Correct the authentication query, enforce server-side checks for each report download, and remove web-accessible backups. Replace weak document passwords and remove internal notes from published metadata. These actions address both entry points and the information exposed after entry.

Scope and methodology

Area	Documented scope
Target application	medirozahospital.com; patient login and report portal
Discovered resources	/robots.txt, /patient/login.php, /patient/portal.php, /old/
Offline analysis	Three downloaded PDFs, password recovery, decrypted report metadata, and the reported SQL backup review
Environment	README lists Windows / Windows 11. A reconnaissance screenshot shows a Kali shell prompt; exact VM or subsystem setup is unspecified.
Authorization	Project owner confirms permission and identifies the site as a practice test project. Formal rules of engagement are not included in the repository.

Assessment approach

The documented workflow follows reconnaissance, manual authentication testing, access validation, offline document analysis, and deeper discovery from exposed information. This report reconstructs those activities from existing evidence; it is not a fresh penetration test or a claim of full standards compliance.

Evidence interpretation

Observed: visible in a supplied screenshot or recorded tool output. **Reported:** described in the README or project brief without a complete transaction. **Inferred:** a technical explanation consistent with the evidence, requiring source code or retesting to confirm.

Coverage and limitations

The source does not provide raw HTTP exchanges, the successful bypass payload, session-cookie history, original PDFs, the complete SQL file, or application code. It contains no evidence of denial-of-service testing, lateral movement, persistence, infrastructure-wide scanning, or database write operations. Those activities are not treated as completed.

The displayed PDF report dates in 2024 are document content dates, not engagement dates. Local filesystem timestamps describe the analyst copy and do not establish when the original document was authored.

Tools used and reconnaissance

Tool / resource	Role and evidence
WHOIS	Domain registration and nameserver information recorded in the README.
WhatWeb	HTTP/HTTPS technology fingerprinting and response details.
nslookup	DNS resolution using 8.8.8.8.
cURL	HTTP headers and retrieval of robots.txt (E01).
WAFW00F	README reports detection of a LiteSpeed WAF in two requests.
Browser / patient portal	Manual login comparisons, SQL-related input tests, report downloads, and directory review (E02-E08, E21).
Network Walks Hash Calculator	Extracted PDF password-verification data in a \$pdf\$ format compatible with password-recovery tools (E09, E12, E15).
Network Walks dictionary attack lab	Tested candidate passwords; a JTR wordlist was used for Report 3. This does not establish that the John the Ripper CLI itself was run (E10, E13, E16-E17).
qpdf / Windows command prompt	Attempted decryption and creation of report3_open.pdf (E19).
ExifTool 13.59	Read metadata from the unlocked PDF (E20).

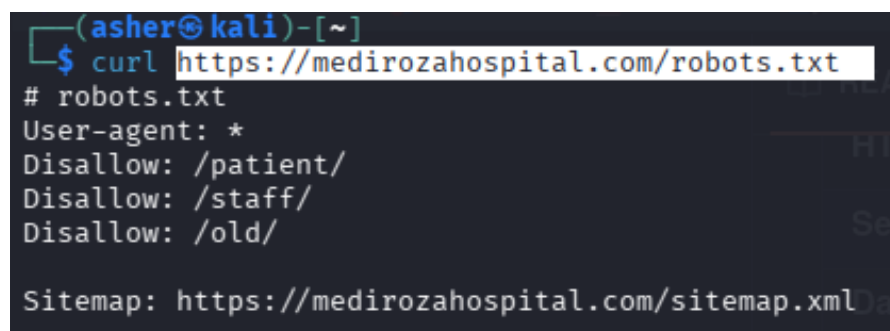
Recorded reconnaissance results

The README records IP address **199.188.201.16**, nameservers **dns1.namecheaphosting.com** and **dns2.namecheaphosting.com**, and OpenResty **1.31.1.1** in HTTP output. Both schemes were reported as returning 200. The recorded cURL response is dated 9 September 2026. [R1]

Fingerprints describe the observed response layer and do not prove an exploitable server version. The WAF detection and the LiteSpeed directory footer do not establish complete infrastructure architecture. No live verification was performed.

Detailed steps taken

- 01.** Collected WHOIS, DNS, HTTP, technology, and WAF observations from the target.
- 02.** Retrieved robots.txt with cURL. Its disallow entries named /patient/, /staff/, and /old/. These are discovery hints, not access restrictions.
- 03.** Navigated to /patient/login.php and compared failed login responses for a placeholder username and admin.
- 04.** Tested SQL-related input. Screenshots show mysqli_query warnings; the next portal screenshot documents report access after the reported bypass. The successful input and request are not preserved.
- 05.** Downloaded three encrypted reports through the portal and extracted their PDF password-verification data with the Network Walks Hash Calculator.
- 06.** Used the dictionary attack lab to recover Report 1 and Report 2 passwords. Report 3 exhausted the built-in list before a JTR wordlist produced a match.
- 07.** Opened the reports using recovered passwords. Used qpdf while producing an unlocked Report 3 copy; earlier command attempts show invalid-password errors. The following ExifTool output confirms an unlocked-copy filename existed.
- 08.** Read the unlocked report metadata. A Comments field identified a backup under /old/. Visited that path and observed a SQL backup listing.
- 09.** Reviewed the SQL information as described in the README and correlated its IT administrator entry with the PDF author. The full SQL content is not embedded in the source.



```
(asher@kali)-[~]  
$ curl https://medirozahospital.com/robots.txt  
# robots.txt  
User-agent: *  
Disallow: /patient/  
Disallow: /staff/  
Disallow: /old/  
  
Sitemap: https://medirozahospital.com/sitemap.xml
```

E01. robots.txt exposes three paths, including the later backup location. [R1]

Username enumeration

MEDIUM | Authentication information disclosure

Affected component: /patient/login.php. The login form distinguishes an unknown username from a wrong password for an existing account. This lets a tester infer that admin exists without completing authentication.

The image displays two side-by-side screenshots of the 'Patient Portal' login interface. Both screenshots show the title 'Patient Portal' and the instruction 'Sign in to view your lab reports and results.' Below this, there are two input fields: 'Username' and 'Password'. A 'Show password' checkbox is located below the password field. A blue 'Sign in' button is at the bottom of each form.

Left Screenshot: The 'Username' field contains the placeholder text 'username'. A red error message 'Username not found' is displayed above the field. The 'Password' field contains the placeholder text 'password'. The 'Show password' checkbox is checked.

Right Screenshot: The 'Username' field contains the text 'admin'. The 'Password' field contains masked characters '.....'. A red error message 'Incorrect password' is displayed above the field. The 'Show password' checkbox is unchecked.

E03-E04. Left: placeholder username receives "Username not found". Right: admin receives "Incorrect password". [R1]

Proof and interpretation

The paired responses provide direct screenshot evidence of account enumeration. They identify an apparent account name, but do not prove that the account has administrator privileges or that its password was recovered.

Potential impact

A reliable account list can make password guessing and targeted social engineering more efficient. No large-scale enumeration or account-password guessing campaign is documented.

Remediation and acceptance test

Return the same generic failure message and consistent response behavior for unknown users and incorrect passwords. Add login throttling and appropriate monitoring. Retest known and unknown usernames: response text, status, and timing should not reliably reveal account existence. [R4]

SQL injection and reported bypass

HIGH | Successful request not retained

Affected component: patient login. E05 and E06 show database syntax warnings after input testing. E06 visibly includes a quote/comment-style username value. That attempt still shows an error and must not be presented as the successful payload.

E05-E06. Database errors are exposed in the login interface; the second screenshot remains a failed attempt. [R1]

E07. Subsequent /patient/portal.php view with report downloads and a logout control. [R1]

Proof of exploitation and evidence boundary

The project reports a SQL injection authentication bypass. SQL warnings and the subsequent portal support that narrative, but screenshots do not establish the exact input, request parameters, session transition, or database query. Unsafe SQL construction is a likely explanation, not a source-code finding.

Remediation and verification

Use prepared statements with bound parameters, verify passwords through a secure password-hash verification function, and grant the application database account only required privileges. Suppress database details in client responses. Retest captured inputs: they must not create a session without valid credentials or alter query logic. [R2]

Confidential PDFs accessible after bypass

HIGH | Downstream confidentiality impact

The portal screenshot lists three encrypted pathology reports. The workflow then shows downloaded PDFs and opened reports labeled confidential. This supports the reported chain from portal access to readable document contents. [R1]

Mediroza

HomeLog out

My lab reports

Your reports are password protected. Use the password sent to you by the laboratory to open each file.

Pathology Report - S. Dlamini

Lab Ref LR-2024-1187 | 2024-11-04 | PDF (encrypted)

Download

Pathology Report - P. Reddy

Lab Ref LR-2024-1192 | 2024-11-05 | PDF (encrypted)

Download

Pathology Report - E. Thompson

Lab Ref LR-2024-1205 | 2024-11-06 | PDF (encrypted)

Download

E08. Three report download entries visible in the patient portal. [R1]

Mediroza

General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:

Sipho Dlamini

Patient ID:

MG-P-10231

Date of Birth:

1984-06-12

Gender:

Male

Report Date:

2024-11-04

Referring Dr:

Dr. Anita Naicker

Specimen:

Whole blood (EDTA)

Lab Ref No:

LR-2024-1187

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	x10 ⁹ /L	4.0 - 11.0	HIGH
Platelet Count	245	x10 ⁹ /L	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

E11. Report 1 is readable after password recovery; original practice-project screenshot. [R1]

E14 and E18 also show opened Reports 2 and 3. The visible fields include patient identity, report references, and laboratory results. The precise direct-download URLs and per-user authorization rules are absent; an independent IDOR or anonymous download vulnerability is not established.

Remediation and acceptance test

Require a valid session and an explicit ownership or role check on every report request. Serve files through a controlled download handler. Verify that anonymous, logged-out, and unrelated accounts cannot retrieve a report, while the intended user can. Document encryption should supplement these controls. [R3]

NETWORK WALKS | B082 | CONFIDENTIAL - PRACTICE PROJECT

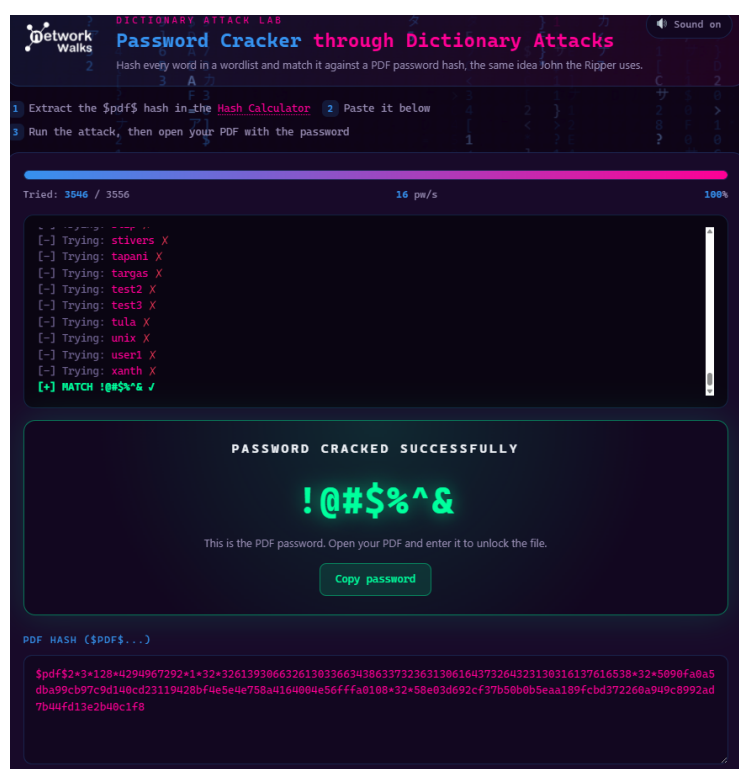
8

Weak PDF passwords

HIGH | Offline dictionary recovery

File	Recovered practice password	Recorded outcome
patient_report_1.pdf	123456	Built-in list match (E10); opened report (E11).
patient_report_2.pdf	password	Built-in list match (E13); opened report (E14).
patient_report_3.pdf	!@#\$\$%^&	Built-in list failed (E16); JTR list matched (E17); opened report (E18).

These are PDF document passwords from the practice evidence, not demonstrated portal credentials. Report 3 shows that a string of symbols can still be predictable when present in a wordlist. Password recovery does not demonstrate a mathematical break of the encryption algorithm.



E17. Report 3 recovery succeeds with the expanded list; the interface displays 3,546 / 3,556 candidates. [R1]

Reproduction record

For each downloaded PDF, the tester extracted \$pdf\$ password-verification data, submitted it to the lab dictionary tool, and used the resulting candidate to open the file. The screenshots identify revision R3, version V2, and 128-bit key length. Exact elapsed time is not recorded reliably.

Remediation and acceptance test

Use long, randomly generated, unique document secrets and a supported modern encryption configuration. Deliver secrets through an appropriate separate channel and prefer authenticated portal access. Reject the demonstrated weak patterns; verify revised sample documents resist the same recorded wordlists. A failed wordlist alone does not prove password strength.

PDF metadata disclosure

MEDIUM | Internal path and author information

ExifTool 13.59 inspected **report3_open.pdf**. Its embedded comments disclose the backup location, linking document analysis to deeper discovery. The following values are transcribed from E20. [R1]

Metadata field	Observed value
Author	j.malik
Comments	DB backup moved to /old before site migration, do not delete
Creator	Mediroza CMS 1.4.2
Producer	Mediroza Lab Reporting Module
Keywords	pathology, patient report
Subject	Full Blood Count
Title	Pathology Report - E. Thompson
Format	PDF 1.4; application/pdf; 1 page; not linearized
Local copy	report3_open.pdf; 2.9 kB; C:/Users/asher/Downloads
Local file times	Created / modified: 2026:09:15 09:39:52-05:00 Accessed: 2026:09:15 09:39:53-05:00

```

ExifTool Version Number      : 13.59
File Name                    : report3_open.pdf
Directory                   : C:/Users/asher/Downloads
File Size                   : 2.9 kB
File Modification Date/Time  : 2026:09:15 09:39:52-05:00
File Access Date/Time       : 2026:09:15 09:39:53-05:00
File Creation Date/Time     : 2026:09:15 09:39:52-05:00
File Permissions             : -rw-rw-rw-
File Type                   : PDF
File Type Extension         : pdf
MIME Type                   : application/pdf
PDF Version                 : 1.4
Linearized                  : No
Author                      : j.malik
Comments                    : DB backup moved to /old before site migration, do not delete
Creator                    : Mediroza CMS 1.4.2
Keywords                    : pathology, patient report
Producer                    : Mediroza Lab Reporting Module
Subject                     : Full Blood Count
Title                       : Pathology Report - E. Thompson
Page Count                  : 1
-- press ENTER --

```

E20. Original metadata output for the unlocked copy. [R1]

The author and CMS values are document metadata claims, not independent proof of authorship or the current deployed CMS version. Local timestamps and size belong to the unlocked copy.

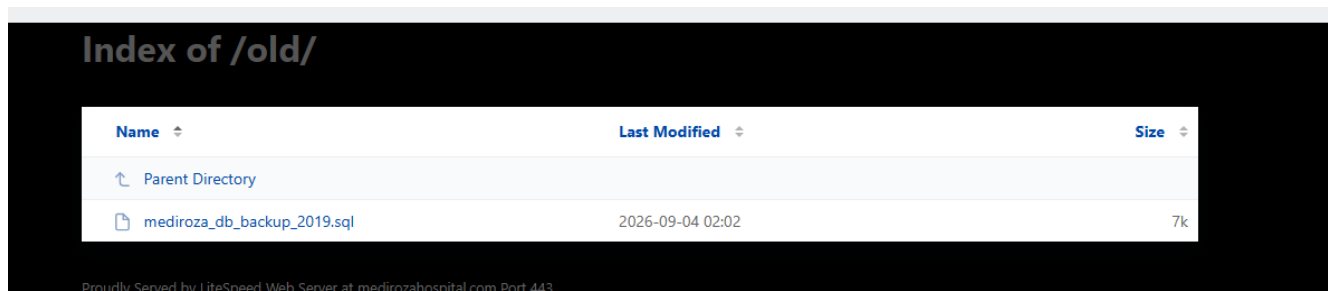
Remediation and acceptance test

Remove internal comments, staff identifiers, and unnecessary software details from distributed PDFs. Add a metadata review to document publishing. Inspect regenerated samples with ExifTool and confirm that internal paths and notes are absent.

Forgotten backup and SQL information

HIGH | Web-accessible backup listing

Both robots.txt and the PDF comment identify /old/. The directory screenshot shows a browsable index with **mediroza_db_backup_2019.sql**, a displayed size of **7k**, and a last-modified value of **2026-09-04 02:02**. The filename alone does not establish the data age. [R1]



E21. Directory index for /old/ exposing the SQL backup filename. [R1]

Steps and proof

01. Followed the /old/ clue already present in robots.txt and reinforced by the PDF metadata.
02. Observed the directory index and SQL backup link.
03. The README reports reading the SQL file and identifying an IT Systems Administrator in the IT department, with a salary field of R58,000. The person name is masked in the README.
04. The README associates this employee with the PDF author, j.malik. This is a reported correlation; the complete SQL record is not supplied for independent comparison.

Access demonstrated versus unproven

The screenshot directly proves directory listing and file-name disclosure. The readable SQL content and personnel entry are supported by the README narrative. There is no preserved download response, file hash, full schema, database credential, or evidence of a live database connection. This finding concerns a backup exposure, not demonstrated database-server control.

Remediation and acceptance test

Move backups outside the web root, restrict backup storage access, and disable directory indexing. Deny direct delivery of SQL dumps and archive files. Review historical access logs and rotate any secrets actually found in exposed backups. Retest the old index and the known file URL directly: neither should return listing or backup content.

Recommendations and remediation

Priority / owner	Required action	Closure evidence
Immediate Application developer	Repair login SQL construction and password verification; hide database errors (F02).	Previously recorded SQL inputs cannot authenticate; parameterized-query review completed.
Immediate Web / platform owner	Remove /old/ backup from web serving; disable indexes (F06).	Directory and exact backup URL return no sensitive content.
Immediate Application developer	Enforce session and report ownership checks on every download (F03).	Anonymous, expired-session, and unrelated-user requests denied.
Next release Document owner	Replace weak document secrets; review encryption and distribution (F04).	New sample documents use unique random secrets and resist the recorded lists.
Next release Application developer	Standardize failed-login responses and add throttling (F01).	Known/unknown account comparison gives no reliable difference.
Next release Document owner	Strip internal notes and unnecessary metadata (F05).	ExifTool review contains no internal path or staff identifier.
Ongoing Security / operations	Review exposure logs, audit deployment artifacts, and keep regression checks.	Review record, backup inventory, and repeatable test results retained.

Priorities and owners are proposed assignments, not evidence that remediation has already occurred. OWASP supports parameterized SQL [R2], per-request authorization [R3], and generic authentication errors with login controls [R4].

Conclusion

The internship demonstrated how several small disclosures can combine into substantial access: account clues, SQL errors, report access, predictable document passwords, internal metadata, and an exposed backup. The strongest direct evidence is the paired login responses, recovered passwords, readable PDFs, metadata output, and backup listing. The reported SQL bypass requires a complete request and session record for reproducible proof.

The project is suitable for demonstrating reconnaissance, manual validation, offline password analysis, and evidence-led discovery. Remediation should be followed by a focused retest against the closure criteria above before the identified controls are considered effective.

Evidence register and references

All E-numbered items are original images embedded in the repository README, numbered in order of appearance. Figures reproduced in this report are scaled for layout. No screenshots were generated from new target requests.

Evidence	README section / content
E01-E02	robots.txt output; route to patient login
E03-E04	Input validation: unknown username versus admin
E05-E07	SQL-related error states; subsequent patient portal
E08	Download reports listing
E09-E11	Report 1 PDF extraction, recovered password, opened report
E12-E14	Report 2 PDF extraction, recovered password, opened report
E15-E18	Report 3 extraction, failed list, successful list, opened report
E19	qpdf command attempts to save an unlocked copy
E20	ExifTool metadata output
E21	Index of /old/ with SQL backup filename

[R1] [Project README and embedded screenshots](#)

[R2] [OWASP SQL Injection Prevention Cheat Sheet](#)

[R3] [OWASP Authorization Cheat Sheet](#)

[R4] [OWASP Authentication Cheat Sheet](#)

Sources reviewed 15 September 2026. The supplied link contained a trailing ".gitcreate"; R1 uses the resolved repository address. Target designation and authorization statement were supplied by the project owner.